

Security+ 4.3 · Vulnerability Scanning

Mestre CyberSec — PDF baseado na aula do Professor Messer · 4.3 — Vulnerability Scanning (7:45) · [vídeo original ↗](#) · [YouTube ↗](#)

Scanner: vulnerability scan (procura CVE conhecido — Nessus, Qualys, OpenVAS); SAST (static — lê o código); fuzzing (input maluco até quebrar). Vulnerability feed alimenta o scanner.

Highlights que a prova cobra

- Vuln scan: compara o sistema com o CVE conhecido
- Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra

Dicas de prova

- 'automated tool checks for known vulnerabilities'=vulnerability scan

Cenário clássico: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. No sistema CVSS 3.1, uma vulnerabilidade com pontuação 9.8 é classificada como:

- A) Baixa
- B) Média
- C) Alta
- D) Crítica

2. Uma vulnerabilidade CVE-2024-1234 pontuou CVSS 3.1 como 7.5 (Alta). O que deve ser feito PRIMEIRO?

- A)** Aplicar patch imediatamente em todos os servidores
- B)** Avaliar o risco no contexto do ambiente específico
- C)** Ignorar pois não é crítica
- D)** Substituir o sistema afetado

3. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Vuln scan: compara o sistema com o CVE conhecido'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido...

4. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'automated tool checks for known vulnerabilities'=vulnerability scan'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando C...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Vuln scan: compara o sistema com o CVE conhecido'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido...

8. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'automated tool checks for known vulnerabilities'=vulnerability scan'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando C...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

1) D — Crítica. CVSS classifica: Baixa (0.1-3.9), Média (4.0-6.9), Alta (7.0-8.9), Crítica (9.0-10.0). Uma pontuação de 9.8 é considerada Crítica.

2) B — Avaliar o risco no contexto do ambiente específico. CVSS fornece severidade técnica, mas o risco real depende de fatores contextuais: exposição do sistema, dados armazenados, controles compensatórios. Deve-se avaliar primeiro.

3) D — Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE con. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Vuln scan: compara o sistema com o CVE conhecido. As demais alternativas configuram violações graves de confor

4) C — Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar —. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra. As demais alternativas configuram

5) A — Implementar a solução correspondente: 'automated tool checks for known vulnerabi. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'automated tool checks for known vulnerabilities'=vulnerability scan. As demais alternativas configuram violaç

6) B — Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-20. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.. As demais alternativas configu

7) D — Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE con. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Vuln scan: compara o sistema com o CVE conhecido. As demais alternativas configuram violações graves de confor

8) A — Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar —. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra. As demais alternativas configuram

9) A — Implementar a solução correspondente: 'automated tool checks for known vulnerabi. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'automated tool checks for known vulnerabilities'=vulnerability scan. As demais alternativas configuram violaç

10) A — Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-20. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.. As demais alternativas configu

